

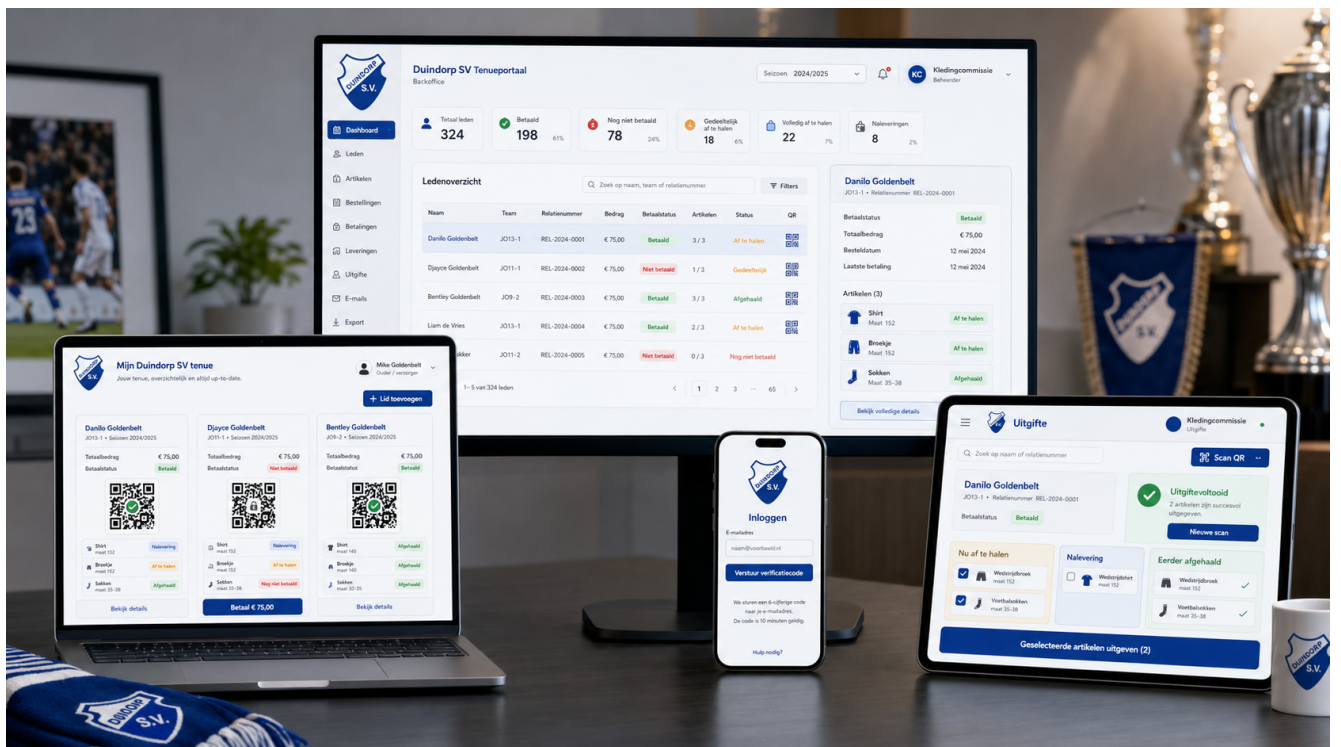


Duindorp SV Tenueportaal

Product-, technische en designcanon

Definitieve MVP-bouwbaseline

Versie 1.0 | 17 juli 2026 | Eigenaar: Duindorp SV



Eén platform. Drie werkvlakken. Eén bindend ontwerp- en gedragsmodel.

Backoffice | Mijn Duindorp SV tenue | Uitgifte

Documentbesturing

CANONSTATUS - BINDEND VOOR DE MVP

Dit document is de enige functionele, technische en visuele bron van waarheid voor de eerste productieversie van het Duindorp SV Tenueportaal. De MVP is geen wegwerpprototype maar de werkende versie die Duindorp SV daadwerkelijk gebruikt. Ontwikkelaars mogen geen extra functies, rollen, workflows of alternatieve ontwerpen toevoegen zonder een formele canonwijziging.

Onderdeel	Vastlegging
Product	Duindorp SV Tenueportaal
Versie	MVP Canon v1.0
Datum	17 juli 2026
Status	Definitieve MVP-bouwbaseline
Organisatie	Duindorp SV
Platformvorm	Eén Next.js applicatie met drie afgeschermd werkvlakken
Werkvlakken	Backoffice, Mijn Duindorp SV tenue, Uitgifte
Taal	Nederlands (nl-NL)
Valuta en tijdzone	EUR en Europe/Amsterdam; opslag van tijdstempels in UTC

Normatieve woorden. “MOET” en “MAG NIET” zijn bindend. “KAN LATER” hoort uitsluitend bij de toekomstige ideeën en is geen onderdeel van de MVP. Bij een conflict geldt de volgende volgorde: beveiliging en dataintegriteit, businessregels, functionele canon, designcanon, visuele voorbeelddata.

Inhoudsopgave

Documentbesturing	2
1. Productdefinitie en uitgangspunten	7
1.1 Productprincipes	7
1.2 Eén product, drie werkvlakken	8
2. Vastgezette MVP-scope	8
2.1 In scope	9
2.2 Expliciet buiten scope	9
2.3 Productgrenzen	10
3. Rollen en autorisatie	10
3.1 Beheerder	11
3.2 Kledingcommissie	11
3.3 Uitgifte	11
4. Canonieke bedrijfsflow	11
5. Functionele canon - Backoffice	12
5.1 Dashboard	12
5.2 Sportlink CSV-import	12
5.3 Leden	13
5.4 Artikelen en maten	13
5.5 Bestellingen per lid	13
5.6 Betalingen	13
5.7 Leveringen en voorraad	14
5.8 E-mails en templates	14
5.9 Export	15
5.10 Instellingen en medewerkers	15
6. Functionele canon - Mijn Duindorp SV tenue	15

6.1 Login met e-mailcode	15
6.2 Meerdere leden op hetzelfde e-mailadres	15
6.3 Dashboard per lid	16
6.4 Betaling per lid	16
6.5 Account en sessie	16
7. Functionele canon - Uitgifte	17
7.1 Scannerstart	17
7.2 Scanresultaat	17
7.3 Bevestigen van uitgifte	17
7.4 Handmatig zoeken	17
7.5 Correcties	18
8. Domein- en statuscanon	18
8.1 Artikelregelstatus	18
8.2 Betaalstatus	18
8.3 Afgeleide orderstatus	18
8.4 Onveranderlijke businessregels	19
9. Datamodelcanon	19
9.1 Sleutels, indexen en constraints	20
9.2 Gegevensminimalisatie	20
10. Technische canon	20
10.1 Verplichte stack	21
10.2 Applicatiestructuur	21
10.3 Routes en schermen	22
10.4 Server- en clientgrens	22
10.5 Achtergrondtaken	23
11. Authenticatie, sessies en autorisatie	23
11.1 Medewerkers via Supabase Auth	23

11.2 Ouder OTP-beveiliging	23
11.3 RLS en databasegrenzen	24
11.4 CSRF, XSS en requestbeveiliging	24
12. Mollie betalingscanon	24
12.1 Aanmaken van een betaling	24
12.2 Webhook is leidend	25
12.3 Idempotentie en dubbele betalingen	25
12.4 Handmatige kas- en pinbetaling	25
12.5 Terugbetalingen en correcties	25
12.6 Mollie productie-gate	25
13. QR-code- en uitgiftebeveiliging	26
14. SendGrid en communicatiecanon	26
14.1 Afzender en deliverability	26
14.2 Templateveiligheid	26
14.3 Bulk verzending	27
15. Import-, export- en auditcanon	27
15.1 Importveiligheid	27
15.2 Exportveiligheid	27
15.3 Auditlog	27
16. Security- en privacycanon	28
16.1 Verplichte technische maatregelen	28
16.2 Privacy en bewaartermijnen	28
16.3 Beveiligingsincidenten	28
17. Niet-functionele eisen	29
17.1 Foutafhandeling	29
18. Designcanon	29

18.1 Merkidentieit	30
18.2 Typografie	31
18.3 Layout en surfaces	31
18.4 Componentcanon	31
18.5 Statuslabels en taal	32
18.6 Motion en interactie	32
18.7 Responsiveness	32
18.8 Wat uit de showcase niet als functie geldt	32
19. Test- en acceptatiecanon	33
19.1 Verplichte end-to-end scenario's	33
19.2 Testlagen	33
19.3 Definition of Done per feature	33
20. Omgevingen, deployment en beheer	34
20.1 Releaseprocedure	34
21. Verplichte bouwvolgorde	34
22. Definitieve MVP-acceptatie	35
23. Wijzigingsbeheer na akkoord	35
Bijlage A. 25 toekomstige ideeën - expliciet geen MVP	36
Bijlage B. Serverendpoint-canon	37
Bijlage C. Configuratie- en secretmatrix	38
Bijlage D. Technische en juridische bronverwijzingen	38

1. Productdefinitie en uitgangspunten

Het Duindorp SV Tenueportaal ondersteunt de volledige keten van ledenimport tot betaling, deel-levering en uiteindelijke uitgifte. De aanleiding is concreet: een tenue wordt niet altijd in één keer geleverd. Broekje en sokken kunnen al beschikbaar zijn terwijl het shirt later volgt. Het platform moet die werkelijkheid zonder losse lijsten, dubbele vouchers of handmatige interpretatie afhandelen.

De minimale productieversie bestaat uit één technisch platform met drie verschillende werkvlakken. De backoffice is voor administratie en kledingbeheer, het ledenportaal is voor ouders en leden, en de uitgifte-app is voor de medewerker die de QR-code scant en artikelen meegeeft. Alle drie gebruiken dezelfde gegevens, statussen, beveiliging en visuele taal.



Dezelfde order en QR-code blijven geldig bij elke deel- en nalevering.

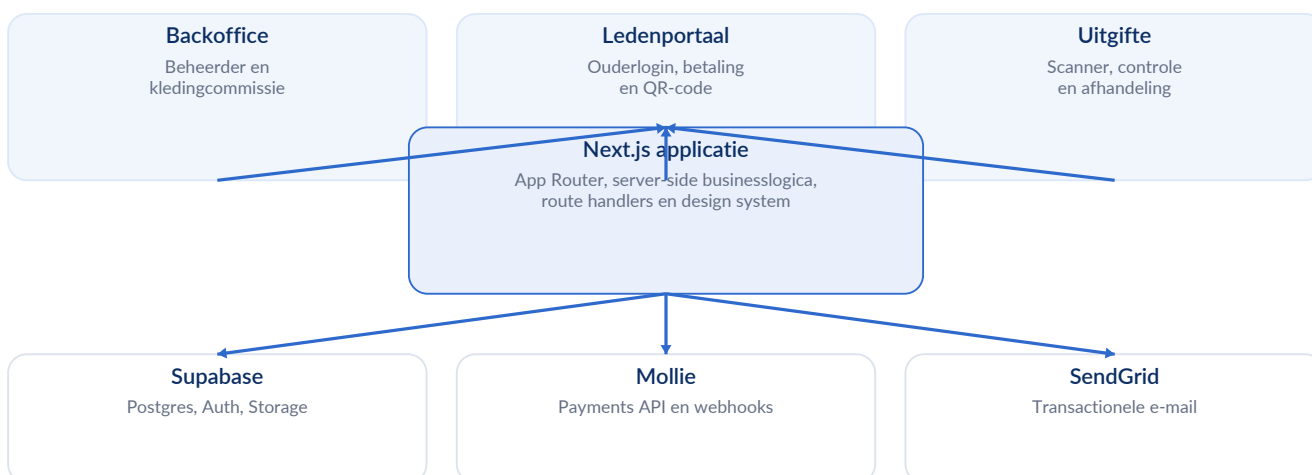
Kernregel

Het lid, niet het huishouden en niet de e-mailgebruiker, is de eenheid van bestelling, bedrag, betaling, QR-code en uitgifte. Eén ouder kan meerdere leden beheren, maar elk lid blijft administratief volledig gescheiden.

1.1 Productprincipes

- Per lid als bron van waarheid. Elk lid heeft per seizoen maximaal één tenuebestelling met één exact verschuldigd bedrag.
- Betaling, logistiek en uitgifte zijn afzonderlijke domeinen. Een betaling maakt een artikel niet automatisch geleverd; een levering maakt een onbetaalde bestelling niet uitgiftebaar.
- Deel-leveringen zijn normaal. Iedere artikelregel heeft zelfstandig de status Nalevering, Af te halen of Afgehaald.
- Eén blijvende QR-code per lid en seizoen. Dezelfde code werkt voor het eerste afhaalmoment en alle naleveringen.
- Eenvoud boven uitbreidbaarheid. Geen multi-tenancy, microservices, webshopfunctionaliteit of generieke workflowbouwer in de MVP.
- Alle relevante handelingen zijn herleidbaar. Betalingen, statuswijzigingen, mails, QR-rotaties, imports en uitgiftes worden gelogd.
- Veilig genoeg voor echte betalingen. Mollie verwerkt betaalgegevens; het portaal bewaart geen kaart- of bankgegevens en accepteert alleen server-gevalideerde betalingsstatussen.

1.2 Eén product, drie werkvlakken



Werkvlak	Primaire gebruiker	Hoofddoel
Backoffice	Beheerder en kledingcommissie	Importeren, beheren, betalen, leveren, communiceren en rapporteren.
Mijn Duindorp SV tenue	Ouder of volwassen lid	Inloggen met e-mailcode, leden koppelen, exact per lid betalen en QR/status bekijken.
Uitgifte	Uitgiftemedewerker	QR scannen, betaalstatus controleren en alleen beschikbare artikelregels uitgeven.

2. Vastgezette MVP-scope

De volgende functies vormen samen de minimale productieversie. “Minimaal” betekent hier niet tijdelijk of onveilig: alle genoemde functies moeten volledig, betrouwbaar en productiegeschikt worden opgeleverd. Alles buiten deze lijst blijft buiten de bouw totdat het canon formeel wordt aangepast.

2.1 In scope

Domein	Bindende MVP-functionaliteit
Leden	Sportlink CSV importeren met kolomkoppeling, validatie, preview en upsert op relatienummer.
Artikelen	Artikelen, maten/varianten en actieve seizoenskoppeling beheren.
Bestellingen	Per lid en seizoen één bestelling met artikelregels, maten en één exact bedrag.
Betalingen	Exacte betaling per lid via kas, pin of Mollie; geen deel- of gezinsbetaling.
Ledenlogin	E-mailadres plus zescijferige code die 10 minuten geldig is; geen Supabase-wachtwoord en geen magic link.
Gezinsweergave	Meerdere leden met hetzelfde e-mailadres optioneel aan één ouderaccount koppelen.
Dashboard lid	Per gekoppeld lid een eigen kaart met bedrag, betaalstatus, QR-code en artikelregels.
Leveringen	Binnengekomen voorraad per artikel en maat registreren en orderregels reserveren/gereedmelden.
Uitgifte	QR scannen, handmatig zoeken als fallback, regels selecteren en atomair als afgehaald registreren.
E-mail	SendGrid API, templates met shortcodes, transactionele mails en bulk gereedmeldingen.
Export	CSV/XLSX exports voor leden, bestellingen, betalingen, leveringen, uitgiftes en openstaande regels.
Beveiliging	Rollen, RLS, MFA voor medewerkers, rate limiting, auditlog, veilige sessies, secrets en webhooks.
Branding	Volledig Duindorp SV, uitsluitend Nederlands, één consistent Enterprise SaaS design.

2.2 Expliciet buiten scope

NIET BOUWEN IN DE MVP

Onderstaande onderwerpen mogen niet "alvast" als verborgen optie, half werkende module of generieke technische voorbereiding worden toegevoegd. Alleen noodzakelijke databasemogelijkheden voor de vastgezette functies zijn toegestaan.

- Eén betaling voor meerdere kinderen, winkelmandjes of huishoudfacturen.
- Deelbetalingen, termijnen, zelf ingevoerde bedragen, kortingen, coupons of sponsorvouchers.
- Een webwinkel voor extra kleding of andere clubartikelen.
- Automatische Sportlink API-synchronisatie; de MVP gebruikt CSV-import.
- Multi-club of white-label SaaS; de applicatie is uitsluitend voor Duindorp SV.
- Native iOS/Android-apps en offline uitgifte. De uitgifte-app is een online web/PWA.
- Retouren, ruilingen, reparaties of prijsverschillen na uitgifte.
- Afhaaltijdsloten, afspraken, wachtrijen of vrijwilligersplanning.
- Boekhoudkoppelingen, fiscale facturatie, incasso of automatische herinneringsschema's.
- Geavanceerde BI, voorspellingen, leveranciersportalen en barcodescanning van voorraad.
- Zelfservice voor het wijzigen van e-mailadres, team, maat of persoonsgegevens door ouders.
- Open- en kliktracking voor e-mailmarketing. Alleen noodzakelijke aflever-/bounce-events worden verwerkt.

2.3 Productgrenzen

Onderwerp	Vaste keuze
Organisatie	Eén vereniging: Duindorp SV. Geen club_id op alle domeintabellen.
Applicatie	Eén repository en één Next.js applicatie. Geen losse frontends of microservices.
Thema	Alleen lichte modus. Geen dark mode en geen themawisselaar.
Taal	Alleen Nederlands. Geen internationalisatie-interface in de MVP.
Betalingseenheid	Eén lid, één seizoen, één exact bedrag.
Voorraad	Eenvoudige ontvangst, reservering en uitgifte per artikelvariant. Geen inkoopmodule.
Internet	Online vereist; bij netwerkstoring kan de uitgifte niet definitief worden opgeslagen.

3. Rollen en autorisatie

De MVP kent exact drie medewerkersrollen. Er komen geen losse permissies, subrollen of maatwerkrechten. Ieder medewerkeraccount heeft precies één rol. Ouderaccounts zijn geen medewerkersrol en volgen een eigen sessiemodel.

Functie	Beheerder	Kledingcommissie	Uitgifte
Dashboard en overzichten	Volledig	Volledig operationeel	Nee
Sportlink import	Ja	Ja	Nee
Leden en teams bekijken	Ja	Ja	Alleen na scan/zoekactie
Artikelen en maten beheren	Ja	Ja	Nee
Bestellingen en bedragen beheren	Ja	Ja, zolang niet betaald	Nee
Kas/pin betaling registreren	Ja	Ja	Nee
Mollie status bekijken	Ja	Ja	Alleen betaald/niet betaald
Leveringen en reserveringen	Ja	Ja	Nee
Bulk e-mail en templates	Ja	Ja	Nee
QR opnieuw sturen	Ja	Ja	Nee
QR intrekken/roteren	Ja	Ja met reden	Nee
Artikelen uitgeven	Ja	Ja	Ja
Uitgifte corrigeren	Ja	Ja met reden	Nee
Exports	Ja	Ja	Nee
Medewerkeraccounts/rollen	Ja	Nee	Nee
Clubinstellingen en productieconfiguratie	Ja	Nee	Nee
Auditlog bekijken	Ja	Beperkt tot operationele acties	Nee

3.1 Beheerder

De beheerder is eindverantwoordelijk voor de applicatie-inrichting. Deze rol beheert medewerkers, het actieve seizoen, clubgegevens, imports, correcties en alle operationele modules. Alleen de beheerder kan medewerkeraccounts activeren of blokkeren, rollen wijzigen en systeeminstellingen aanpassen.

3.2 Kledingcommissie

De kledingcommissie voert de dagelijkse kledingadministratie uit. Deze rol kan leden importeren, artikelen en maten koppelen, bedragen vóór betaling instellen, betalingen via kas of pin registreren, leveringen verwerken, bulkmail sturen, QR-codes opnieuw aanbieden en gecorrigeerde uitgiftes vastleggen. De rol kan geen medewerkers of productie-instellingen beheren.

3.3 Uitgifte

De uitgifterol is bewust minimaal. Na scan of handmatige zoekactie ziet de medewerker uitsluitend de naam, het team, de globale betaalstatus en de artikelregels van het betreffende lid. E-mailadressen, adressen, telefoonnummers, betalingsdetails, exports en overige leden zijn niet zichtbaar. De rol kan uitsluitend regels met status Af te halen selecteren en uitgeven.

Geen betaaloverride bij de balie

De uitgifterol kan een onbetaalde bestelling nooit vrijgeven, een bedrag aanpassen of een betaling registreren. Bij een afwijking moet de kledingcommissie of beheerder de administratie eerst corrigeren.

4. Canonieke bedrijfsflow

Iedere productiehandeling volgt dezelfde keten. Afwijkende spreadsheets, papieren aftekenlijsten of parallelle QR-systemen zijn na ingebruikname geen bron van waarheid meer.

- 1Seizoen openen. Beheerder maakt het seizoen aan, stelt het standaardbedrag in en activeert de relevante artikelen en maten.
- 2Leden importeren. Sportlink CSV wordt gevalideerd en op relatienummer verwerkt. Dubbele ouder-e-mailadressen zijn toegestaan.
- 3Bestellingen samenstellen. Per lid wordt één bestelling aangemaakt met exact bedrag en artikelregels voor shirt, broekje, sokken of andere geconfigureerde artikelen.
- 4Betaling uitvoeren. De ouder betaalt uitsluitend het bedrag van één lid via Mollie, of de kledingcommissie registreert exact hetzelfde bedrag als kas of pin.
- 5Levering registreren. Binnengekomen aantallen worden per artikelvariant geboekt. Regels worden vervolgens aan leden gereserveerd en Af te halen gezet.
- 6Gereedmelding verzenden. Geselecteerde leden ontvangen een e-mail met beschikbare regels en hun lidgebonden QR-code.
- 7QR scannen. Een ingelogde uitgiftemedewerker scant de code. Het systeem controleert live betaling, token en actuele regels.
- 8Artikelen uitgeven. Alleen aangevinkte, beschikbare regels worden in één database-transactie Afgehaald. Niet geleverde regels blijven Nalevering.
- 9Nalevering herhalen. Bij binnenkomst van het shirt wordt dezelfde order en QR-code opnieuw gebruikt; alleen de nieuwe regel wordt uitgegeven.
- 10Seizoen afronden. Openstaande regels en betaalverschillen worden geëxporteerd en het seizoen wordt alleen-lezen gearchiveerd.

Geen nieuwe QR per nalevering

De QR-code identificeert de tenuebestelling van één lid in één seizoen. De inhoud van de QR verandert niet wanneer een artikelstatus wijzigt; de scanner haalt altijd de actuele toestand van de server.

5. Functionele canon - Backoffice

De backoffice is een desktop-first Enterprise SaaS dashboard. De vaste hoofdnavigatie is: Dashboard, Leden, Artikelen, Bestellingen, Betalingen, Leveringen, Uitgifte, E-mails en Export. Instellingen en medewerkerbeheer zijn bereikbaar via het accountmenu en uitsluitend voor de beheerder.

5.1 Dashboard

Het dashboard toont de operationele stand van het geselecteerde seizoen. De bovenste KPI-rij bevat exact: Totaal leden, Betaald, Nog niet betaald, Gedeeltelijk af te halen, Volledig af te halen en Naleveringen. Een klik op een KPI opent de Leden- of Bestellingenlijst met het overeenkomstige filter.

- Seizoenswisselaar rechtsboven; alleen geopende en gearchiveerde seizoenen zijn selecteerbaar.
- Ledenoverzicht met zoeken op naam, team en relatienummer.
- Filterpaneel voor team, betaalstatus, bestelstatus, artikel, maat en uitgiftestatus.
- Selectie van een rij opent een detailpaneel aan de rechterzijde; geen volledige paginawissel nodig.
- Het detailpaneel toont orderbedrag, betaalstatus, betalingsdatum, artikelregels, QR-status en relevante historie.
- Dashboardcijfers worden server-side berekend en niet door optelling in de browser.

5.2 Sportlink CSV-import

De import bestaat uit vier vaste stappen: upload, kolomkoppeling, preview en commit. Het bestand mag maximaal 10 MB zijn en moet CSV/UTF-8 of een door de browser leesbaar CSV-formaat bevatten. De applicatie importeert uitsluitend de velden die voor dit portaal noodzakelijk zijn.

Veld	Verplicht	Regel
Relatienummer	Ja	Unieke externe sleutel; wordt getrimd en hoofdletterongevoelig vergeleken.
Voornaam	Ja	Weergavenaam; geen lege waarde.
Tussenvoegsel	Nee	Wordt los opgeslagen.
Achternaam	Ja	Geen lege waarde.
E-mailadres	Ja voor ledenportaal	Wordt getrimd en lowercase opgeslagen; hetzelfde e-mailadres mag bij meerdere leden voorkomen.
Team	Ja	Vrije tekst uit Sportlink, bijvoorbeeld JO13-1.
Actief voor seizoen	Ja	Alleen actieve leden worden als koppelbare kandidaat aangeboden.

- Preview toont aantallen nieuw, bijgewerkt, ongewijzigd, ongeldig en dubbel relatienummer.
- Een e-mailadres dat bij meerdere leden voorkomt is informatief, geen fout.
- De commit draait in één transactie: bij een fatale fout wordt niets gedeeltelijk opgeslagen.
- De import verwijdert nooit automatisch leden, bestellingen of betalingen.
- Iedere batch bewaart bestandsnaam, checksum, actor, tijdstip en samenvatting voor audit.
- Onnodige Sportlinkvelden zoals adres, telefoonnummer en geboortedatum worden niet geïmporteerd.

5.3 Leden

De ledenlijst is het centrale operationele overzicht. De detailweergave bevat basisgegevens, huidige bestelling, gekoppelde ouderaccounts en een chronologische activiteitenlijn. Persoonsgegevens worden alleen getoond voor zover zij nodig zijn voor tenuebeheer.

Actie	Beheerder	Kledingcommissie	Regel
Lid bekijken	Ja	Ja	Volledige operationele detailweergave.
Team/e-mail handmatig corrigeren	Ja	Ja	Wordt gelogd; volgende import kan opnieuw bijwerken.
Lid actief/inactief zetten	Ja	Ja	Inactief blokkeert nieuwe betaling en nieuwe toewijzingen.
Ouderkoppeling verwijderen	Ja	Ja	Verwijdert alleen de link, nooit het lid of de order.
QR opnieuw versturen	Ja	Ja	Bestaande actieve QR; geen rotatie.
QR roteren	Ja	Ja	Oude token direct ongeldig; reden verplicht.

5.4 Artikelen en maten

Een artikel is een logisch kledingonderdeel. Een variant is de maat of maatgroep. De standaardartikelen zijn Shirt, Broekje en Sokken, maar de kledingcommissie kan aanvullende artikelen toevoegen. Artikelen hebben in de MVP geen losse verkoopprijs; het verschuldigde bedrag staat op de bestelling van het lid.

- Artikelvelden: naam, korte code, type/icoon, actief, sorteervolgorde en gekoppelde seizoenen.
- Variantvelden: maatlabel, leverancierscode optioneel, actief en sorteervolgorde.
- Een maat wordt vastgelegd op de orderregel, zodat historie per seizoen behouden blijft.
- Een gebruikte variant mag niet hard worden verwijderd; alleen inactief worden gemaakt.
- Artikeliconen volgen één consistente lijnstijl en komen uit de gekozen iconset, niet uit losse foto's.

5.5 Bestellingen per lid

Per lid en seizoen bestaat maximaal één bestelling. De bestelling bevat het exacte bedrag en één of meer artikelregels. Het seizoensbedrag kan als standaard worden gekopieerd, maar is per lid vóór betaling aanpasbaar door beheerder of kledingcommissie.

Regel	Canon
Uniciteit	Unieke databaseconstraint op lid + seizoen.
Bedrag	Integer in eurocenten; minimaal 0; valuta vast EUR.
Aanpassing vóór betaling	Toegestaan en gelogd.
Aanpassing na betaling	Geblokkeerd totdat een beheerder de betaling met reden terugdraait of als terugbetaald verwerkt.
Artikelregels	Per artikel maximaal één actieve regel, tenzij expliciet meer stuks zijn ingesteld.
Verwijderen	Vóór betaling toegestaan; daarna alleen annuleren/soft-delete met audit.
QR	Eén actieve token per bestelling; pas bruikbaar voor uitgifte na volledige betaling.

5.6 Betalingen

Het betalingsoverzicht combineert Mollie-betalingen en handmatige betalingen in één register. Iedere regel hoort bij precies één bestelling. De operator ziet lid, seizoen, exact bedrag, methode, status, providerreferentie, datum en actor.

- Handmatige methoden zijn uitsluitend Kas en Pin.
- Het bedrag is read-only en komt server-side uit de bestelling.
- Een handmatige betaling is een expliciete bevestiging; de medewerker voert geen bedrag in.
- Een betaalrecord wordt nooit verwijderd of overschreven; correcties ontstaan als afzonderlijke audit- of reversaalgebeurtenis.
- Mollie-betalingen kunnen open, pending, paid, failed, canceled, expired of refunded zijn.
- De bestelling wordt alleen Betaald wanneer exact bedrag, EUR, ordermetadata en status paid server-side overeenkomen.

5.7 Leveringen en voorraad

De leveringsmodule is bewust eenvoudig: er wordt voorraad ontvangen per artikelvariant, vervolgens wordt één stuk gereserveerd voor een concrete orderregel. De module ondersteunt daarmee gecontroleerde deel-leveringen zonder volledige inkoopadministratie.

- 1Maak een levering aan met datum, leverancier en pakbonreferentie.
- 2Voeg regels toe met artikelvariant en ontvangen aantal.
- 3Open de wachtlijst voor dezelfde variant en selecteer de leden die een stuk krijgen.
- 4Bevestig de reserveringen; het systeem voorkomt reserveren boven beschikbare voorraad.
- 5De geselecteerde orderregels krijgen status Af te halen. Andere regels blijven Nalevering.
- 6Start eventueel direct een bulk gereedmelding voor de geselecteerde regels.

De voorraad wordt als ledger afgeleid: ontvangen minus uitgegeven en correcties. “Beschikbaar” is fysiek aanwezig minus actieve reserveringen. Bij een correctie is een reden verplicht en wordt het verschil in het auditlog opgenomen.

5.8 E-mails en templates

Alle e-mail wordt via SendGrid verzonden vanuit een geauthenticeerd Duindorp SV-domein. De applicatie bewaart zelf de template-inhoud en vervangt een beperkte set toegestane shortcodes server-side. Vrije scripts, externe formulieren en ongesaniteerde HTML zijn niet toegestaan.

Template	Trigger
Verificatiecode	Ouder vraagt een zescijferige code aan.
Betalingsverzoek	Bestelling is compleet en betaling staat open.
Betaling ontvangen	Exacte betaling is definitief bevestigd.
Artikelen af te halen	Eerste of aanvullende regels zijn gereed.
Betalingsherinnering	Handmatige bulkactie op openstaande bestellingen.
QR-code opnieuw verzonden	Beheerder/kledingcommissie kiest opnieuw versturen.

Toegestane shortcodes: `{{voornaam}}`, `{{volledige_naam}}`, `{{team}}`, `{{relatienummer}}`, `{{seizoen}}`, `{{bedrag}}`, `{{betaallink}}`, `{{qr_code}}`, `{{artikelen_af_te_halen}}`, `{{artikelen_nalevering}}`, `{{afhaallocatie}}`, `{{clubnaam}}` en `{{contact_email}}`.

- Bulkmail is altijd gebaseerd op een zichtbare filter/selectie en toont vooraf ontvangersaantal en voorbeeld.
- Iedere geselecteerde bestelling genereert een eigen bericht per lid; QR-codes worden niet tussen kinderen gecombineerd.
- Een e-mailjob draait asynchroon in batches en kan veilig opnieuw worden uitgevoerd zonder dubbele verzending.
- Alleen delivered, bounced, deferred, dropped en failed worden als operationele events opgeslagen; open/click tracking staat uit.

5.9 Export

Exports zijn filterbaar en worden server-side gegenereerd. CSV gebruikt UTF-8 met BOM voor correcte opening in Nederlandse Excel-installaties; XLSX is de tweede standaard. Potentiële spreadsheetformules in tekstvelden worden geneutraliseerd om CSV-formule-injectie te voorkomen.

Export	Minimale kolommen
Leden	Relatienummer, naam, team, e-mail, actief, gekoppelde ouderstatus.
Bestellingen	Lid, seizoen, bedrag, betaalstatus, orderstatus, aantallen per artikelstatus.
Betalingen	Order, lid, bedrag, methode, status, referentie, datum, actor.
Leveringen	Levering, datum, variant, ontvangen, gereserveerd, beschikbaar.
Uitgiftes	Lid, regel, artikel, maat, datum, uitgifterol/account, correctiestatus.
Openstaand	Niet betaald, naleveringen en niet afgehaalde gereedstaande regels.

5.10 Instellingen en medewerkers

De beheerder kan de clubnaam, logo, contact-e-mail, afhaallocatie, actieve seizoenen, standaardbedrag en medewerkeraccounts beheren. De branding blijft Duindorp SV; de instellingen zijn geen white-label configuratie. Logo-upload accepteert uitsluitend PNG of WebP, maximaal 2 MB.

6. Functionele canon - Mijn Duindorp SV tenue

Het ledenportaal is mobile-first, maar gebruikt op desktop dezelfde hoogwaardige card-layout als in de vastgezette showcase. Ouders krijgen geen Supabase-wachtwoord, geen magic link en geen accountregistratieformulier. Toegang ontstaat uitsluitend via een korte e-mailcode.

6.1 Login met e-mailcode

- 1De gebruiker voert uitsluitend het e-mailadres in en kiest “Verstuur verificatiecode”.
- 2De server geeft altijd dezelfde neutrale reactie: “Als dit e-mailadres bij ons bekend is, is een code verzonden.”
- 3Bij een bekende, actieve kandidaat genereert de server cryptografisch veilig een zescijferige code.
- 4De code wordt gehasht opgeslagen, is eenmalig bruikbaar en verloopt exact 10 minuten na uitgifte.
- 5De gebruiker voert de code in; na maximaal vijf mislukte pogingen wordt de code ongeldig.
- 6Na succesvolle verificatie wordt een eigen ouderaccount/sessie aangemaakt zonder Supabase Auth-gebruiker.
- 7De sessie staat in een HttpOnly, Secure, SameSite-cookie en verloopt uiterlijk na 30 dagen.

Geen e-mail-enumeratie

De loginpagina onthult nooit of een e-mailadres, lid of gezin bestaat. Ook responstijd en foutmelding moeten zo gelijk mogelijk blijven.

6.2 Meerdere leden op hetzelfde e-mailadres

Na de eerste succesvolle login zoekt het systeem naar actieve leden in het geselecteerde seizoen met hetzelfde genormaliseerde e-mailadres. Het koppelen is expliciet en optioneel; een gelijk e-mailadres leidt nooit automatisch tot het koppelen van alle leden.

Situatie	Gedrag
Exact één actief, nog niet gekoppeld lid	Dat lid wordt direct gekoppeld en het dashboard opent.
Meerdere actieve kandidaten	Keuzescherf met naam, team en seizoen. De ouder selecteert één of meer leden; overige kandidaten blijven ongekoppeld.
Ouder kiest niet alle kandidaten	Geen fout. Niet gekozen leden blijven beschikbaar via "Lid toevoegen".
Lid is gestopt of niet relevant	Ouder laat het lid ongekoppeld; er ontstaat geen dashboardkaart.
Geen actieve kandidaten	Leeg dashboard met instructie om contact op te nemen met Duindorp SV.
Later lid toevoegen	Knop "Lid toevoegen" toont uitsluitend nog ongekoppelde kandidaten met hetzelfde e-mailadres.
Lid ontkoppelen	Ouder kan een kaart verbergen/ontkoppelen; de clubadministratie en bestelling blijven bestaan.

6.3 Dashboard per lid

Elk gekoppeld lid verschijnt in een eigen container. Kaarten worden op desktop naast elkaar geplaatst wanneer ruimte beschikbaar is en op mobiel onder elkaar. Er is geen gezamenlijke gezinskaart en er is geen totaal som over meerdere kinderen.

Element	Vaste inhoud
Kop	Naam, team en seizoen.
Betaling	Exact totaalbedrag en label Nog te betalen, Betaling wordt verwerkt, Betaald of Terugbetaald.
CTA	"Betaal € 75,00" met het exacte orderbedrag van dit lid; niet getoond als betaald.
QR	Unieke QR-code voor dit lid/seizoen; vergrendelde weergave zolang niet betaald.
Artikelregels	Artikel, maat en één van de zichtbare statussen Nalevering, Af te halen of Afgehaald.
Acties	QR groot tonen, opnieuw per e-mail ontvangen, details bekijken en lid ontkoppelen.

De artikelstatus beschrijft de logistieke toestand. De betaling staat apart. Een regel kan fysiek gereed zijn terwijl de betaling nog openstaat, maar de QR blijft geblokkeerd en de uitgifte-app weigert de afhandeling tot de exacte betaling bevestigd is.

6.4 Betaling per lid

Harde betaalregel

De ouder kan nooit zelf een bedrag invoeren, meerdere leden selecteren of een deelbedrag voldoen. Iedere knop start één Mollie-betaling voor exact één lid en exact één bestelling.

- Het bedrag in de browser is alleen presentatie; de server leest het bedrag opnieuw uit de database.
- Tijdens een actieve open/pending betaalpoging wordt niet onbeperkt een nieuwe betaling aangemaakt.
- De redirect na Mollie toont uitsluitend "betaling wordt gecontroleerd" totdat de webhook/API-status definitief is verwerkt.
- Na paid wordt de QR direct actief en ontvangt de ouder een betalingsbevestiging.
- Een mislukte, geannuleerde of verlopen betaling opent de knop opnieuw zonder de bestelling te wijzigen.

6.5 Account en sessie

Het accountscherf toont het ingelogde e-mailadres, gekoppelde leden, actieve sessie en uitlogactie. Ouders kunnen geen ledengegevens of bedragen aanpassen. "Uitloggen op alle apparaten" trekt alle ouder-sessietokens voor het e-mailadres in.

7. Functionele canon - Uitgifte

De uitgifte-app is tablet-first en installeerbaar als PWA, maar blijft online-only. Het scherm gebruikt grote aanraakdoelen, minimale navigatie en directe feedback. De primaire actie is scannen; zoeken op naam of relatienummer is de gecontroleerde fallback.

7.1 Scannerstart

- Titel "Uitgifte" met Duindorp SV-logo en ingelogde medewerker rechtsboven.
- Grote knop/zone "Scan QR" die cameratoestemming pas na gebruikersactie vraagt.
- Zoekveld "Zoek op naam of relatienummer".
- Geen dashboard, betalingslijst, export of vrij bladeren door alle leden.
- Camera wordt alleen gebruikt op de scannerpagina en nooit op de achtergrond.

7.2 Scanresultaat

Na een geldige scan toont het scherm naam, team, relatienummer in verkorte vorm, betaalstatus en drie groepen: Nu af te halen, Nalevering en Eerder afgehaald. Alleen regels in de eerste groep hebben een selectievakje.

Situatie	Schermgedrag
Betaald + regels gereed	Selecteerbare regels en primaire knop "Geselecteerde artikelen uitgeven".
Niet betaald	Rode blokkade; geen selectievakjes en geen override.
QR ingetrokken/ongeldig	Neutrale fout, geen lidinformatie.
Alles al afgehaald	Groene melding "Bestelling volledig afgehaald"; historie zichtbaar.
Alleen nalevering	Geen uitgiftekноп; melding dat nog niets beschikbaar is.
Dubbele scan tijdens afhandeling	Server blokkeert dubbele uitgifte en vernieuwt actuele status.

7.3 Bevestigen van uitgifte

- 1 Medewerker vinkt één of meer gereedstaande regels aan.
- 2 Knop toont het aantal, bijvoorbeeld "Geselecteerde artikelen uitgeven (2)".
- 3 Server controleert opnieuw rol, betaling, QR, regelstatus en reservering.
- 4 Alle geselecteerde regels worden in één database-transactie Afgehaald gezet.
- 5 Fulfilment en fulfilmentregels worden aangemaakt met actor, locatie, tijdstip en orderregels.
- 6 Succesvenster toont "Uitgifte voltooid", tijdstip, aantal en knop "Nieuwe scan".

Atomair en dubbel-uitgiftebestendig

Twee apparaten mogen dezelfde order niet tegelijk kunnen uitgeven. De transactie gebruikt database-locking en een unieke constraint op actieve fulfilment per orderregel.

7.4 Handmatig zoeken

Zoeken is alleen toegestaan na expliciete invoer van minimaal drie tekens of een volledig relatienummer. Resultaten tonen uitsluitend naam en team. Het openen van een resultaat wordt gelogd. Handmatig zoeken geeft geen extra rechten en volgt exact dezelfde betaal- en statuscontroles als een QR-scan.

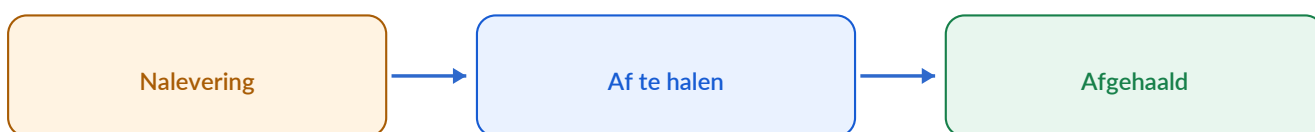
7.5 Correcties

De uitgifterol kan een afgeronde uitgifte niet terugdraaien. Beheerder en kledingcommissie kunnen vanuit de backoffice een foutieve uitgifte corrigeren. Zij kiezen de betreffende regels, geven een verplichte reden en bepalen of de regel teruggaat naar Af te halen of Nalevering. De oorspronkelijke fulfilment blijft intact in de historie.

8. Domein- en statuscanon

Het datamodel moet de werkelijke bedrijfsregels afdwingen. UI-labels zijn geen vervanging voor databaseconstraints. De belangrijkste entiteiten zijn seizoen, lid, ouderaccount, bestelling, orderregel, betaling, levering/reservering, QR-token, fulfilment en e-mailjob.

8.1 Artikelregelstatus



Terugzetten is alleen toegestaan als gecorrigeerde, gelogde beheeractie.

Interne status	Zichtbaar label	Betekenis	Toegestane volgende status
backorder	Nalevering	Nog niet voor dit lid gereserveerd of beschikbaar.	ready_for_pickup of cancelled
ready_for_pickup	Af te halen	Eén stuk is gereserveerd; nog niet uitgegeven.	picked_up; alleen correctie terug naar backorder
picked_up	Afgehaald	Regel is in een fulfilment uitgegeven.	Alleen gecorrigeerde reversal door beheerder/kledingcommissie
cancelled	Niet zichtbaar	Regel administratief geannuleerd.	Geen normale overgang

8.2 Betaalstatus

Status	UI-label	Effect op QR/uitgifte
open	Nog te betalen	QR vergrendeld; uitgifte geblokkeerd.
pending	Betaling wordt verwerkt	QR vergrendeld totdat Mollie paid bevestigt.
paid	Betaald	QR actief; gereedstaande regels mogen worden uitgegeven.
failed/canceled/expired	Nog te betalen	Nieuwe betaalpoging toegestaan.
refunded	Terugbetaald	QR direct geblokkeerd; openstaande uitgifte niet toegestaan.

8.3 Afgeleide orderstatus

De orderstatus wordt niet los door gebruikers gekozen maar server-side afgeleid uit betaling en orderregels. Daarmee kunnen dashboardcijfers niet uit elkaar lopen.

UI-status	Afleidingsregel
Nog niet betaald	Payment status is niet paid.
Nalevering	Paid en alle actieve regels zijn backorder.

UI-status	Afleidingsregel
Gedeeltelijk af te halen	Paid, minstens één ready_for_pickup en minstens één backorder.
Volledig af te halen	Paid en alle niet-afgehaalde actieve regels zijn ready_for_pickup.
Gedeeltelijk afgehaald	Minstens één picked_up en minstens één actieve regel niet picked_up.
Afgerond	Alle actieve regels zijn picked_up.

8.4 Onveranderlijke businessregels

- Uniek: één member_order per member_id + season_id.
- Uniek: één actieve QR-token per bestelling.
- Uniek: een orderregel kan maximaal één niet-teruggedraaide uitgifte hebben.
- Geld: alle bedragen als integer eurocenten; nooit floating point.
- Betaling: order is alleen paid na exact bedrag en EUR.
- Handmatig: kas/pin-record heeft exact amount_due_cents en geen vrij bedragveld.
- Uitgifte: alleen bij paid en ready_for_pickup.
- Voorraad: reserveringen mogen beschikbare voorraad niet negatief maken.
- Historie: transacties, betaalrecords, fulfilments en auditlogs worden nooit hard verwijderd.
- Tijd: alle databasevelden timestamptz in UTC; presentatie in Europe/Amsterdam.

9. Datamodelcanon

Supabase Postgres is de primaire datastore. Tabellen met directe UI-data staan in een afgeschermd applicatieschema met RLS; secrets, OTP's, sessietokens, QR-tokenhashes en auditdetails staan in een niet via de Data API blootgesteld private schema. De browser schrijft geen transactionele tabellen rechtstreeks aan.

Tabel	Schema	Doel en belangrijkste velden
app_settings	app	Singleton: clubnaam, logo, contact, afhaalallocatie, actieve season_id, feature flags Mollie/SendGrid.
seasons	app	id, naam, start/end, default_amount_cents, status open/archived, opened_at, archived_at.
staff_profiles	app	auth_user_id, naam, role beheerder/kledingcommissie/uitgifte, active, last_login_at.
import_batches	app	bestand, checksum, mapping JSON, actor, counts, status, created_at.
members	app	relatienummer, voornaam, tussenvoegsel, achternaam, email_normalized, team, active, source timestamps.
parent_accounts	app	email_normalized, created_at, last_login_at, blocked_at. Geen wachtwoord.
parent_member_links	app	parent_account_id, member_id, linked_at, unlinked_at; unieke actieve combinatie.
parent_login_codes	private	email, code_hash, expires_at, attempts, used_at, request_ip_hash.
parent_sessions	private	parent_account_id, token_hash, expires_at, revoked_at, last_seen_at, user_agent summary.
products	app	naam, code, icon_type, active, sort_order.
product_variants	app	product_id, maatlabel, supplier_code, active, sort_order.
member_orders	app	member_id, season_id, amount_due_cents, payment_state cache, qr_active, timestamps.
member_order_lines	app	order_id, product_id, variant_id, quantity, line_status, reserved_at, picked_up_at, cancelled_at.
stock_receipts	app	receipt_no, supplier, received_at, note, actor.

Tabel	Schema	Doel en belangrijkste velden
stock_receipt_lines	app	receipt_id, variant_id, quantity_received, quantity_corrected.
stock_reservations	app	order_line_id, variant_id, reserved_at, released_at; één actieve reservering per orderregel.
payments	app	order_id, method mollie/cash/pin, amount_cents, currency, status, provider_id, created/paid/refunded_at.
payment_events	private	payment_id, event_type, provider_payload_redacted, processed_at, idempotency_key.
qr_tokens	private	order_id, token_hash, active, issued_at, revoked_at, rotated_by.
fulfilments	app	order_id, actor_id, location, fulfilled_at, corrected_at, correction_reason.
fulfilment_lines	app	fulfilment_id, order_line_id, reversed_at, reversal_reason; unieke actieve uitgifte.
email_templates	app	type, subject, body_source, allowed_shortcode, active, version.
email_jobs	app	template_id, order_id, recipient, payload JSON, status, attempts, scheduled/sent_at.
email_events	private	email_job_id, provider_message_id, event, occurred_at, payload_redacted.
audit_logs	private	actor_type/id, action, entity, entity_id, before/after redacted, ip_hash, created_at.
rate_limit_events	private	scope, key_hash, occurred_at; korte retentie voor OTP, scan en betaalendpoints.

9.1 Sleutels, indexen en constraints

- UUID primary keys via `gen_random_uuid()`; externe relatienummers blijven aparte unieke sleutels.
- Unieke index op lower/normalized relatienummer en op `member_orders(member_id, season_id)`.
- Indexen op `members(email_normalized)`, `members(team)`, `orderregels(status, variant_id)`, `payments(provider_id)` en `email_jobs(status, scheduled_at)`.
- Check constraints voor non-negatieve aantallen, EUR, `amount_cents >= 0` en toegestane enums.
- Foreign keys met `restrict/no action` op financiële en fulfilmenthistorie; geen cascades die transacties verwijderen.
- Database-trigger of transactiefunctie houdt `reserved/picked_up` tijdstempels en statusovergangen consistent.

9.2 Gegevensminimalisatie

De MVP importeert en bewaart geen adres, telefoonnummer, geboortedatum, BSN, bankrekening of kaartgegevens. Voor de uitvoering zijn naam, relatienummer, team en e-mailadres voldoende. Dit beperkt zowel privacyrisico als de impact van een mogelijk incident.

10. Technische canon

De oplossing wordt gebouwd als één moderne, servergerichte Next.js applicatie. Het project gebruikt TypeScript, Tailwind CSS, shadcn/ui en Motion voor alle drie werkvlakken. Supabase levert Postgres, medewerker-authenticatie en beperkte bestandsopslag. Mollie en SendGrid worden uitsluitend server-side aangeroepen.

10.1 Verplichte stack

Laag	Vaste keuze
Framework	Next.js App Router met TypeScript strict mode.
UI	Tailwind CSS, shadcn/ui componenten en Lucide-iconen.
Motion	Motion for React; alleen functionele micro-interacties en reduced-motion ondersteuning.
Database	Supabase Postgres met SQL-migraties, constraints en RLS.
Medewerkerauth	Supabase Auth SSR, e-mail/wachtwoord en verplichte TOTP MFA.
Ouderauth	Eigen OTP- en sessiemodel in Postgres; geen Supabase wachtwoord/magic link/account.
Bestandsopslag	Supabase Storage uitsluitend voor clublogo/branding indien upload gebruikt wordt.
Betaling	Mollie Payments API; hosted checkout en webhooks. Geen Orders API.
E-mail	Twilio SendGrid Mail Send API en event webhook.
Validatie	Zod aan alle servergrenzen; databaseconstraints blijven de laatste verdedigingslaag.
Tests	Vitest voor unit/integratie en Playwright voor end-to-end.
Build/dependency	pnpm lockfile, vaste dependencyversies, Node.js actieve LTS bij projectstart.

10.2 Applicatiestructuur

```
src/  
  app/  
    (public)/login  
    (member)/mijn-tenue  
    (staff)/backoffice  
    (staff)/uitgifte  
    api/webhooks/mollie  
    api/webhooks/sendgrid  
    api/internal/jobs/email  
  components/  
    design-system/  
    backoffice/  
    member/  
    fulfilment/  
  server/  
    auth/  
    payments/  
    inventory/  
    email/  
    repositories/  
    audit/  
  lib/  
    validation/  
    formatting/  
    security/  
  supabase/  
    migrations/  
    seed/
```

- Server Components zijn de standaard voor pagina's en datalezen; Client Components alleen voor formulieren, scanner, dialogs en interactieve tabellen.
- Businesslogica staat in server-only services en niet in React-componenten.
- Alle externe webhookroutes gebruiken de Node runtime, dynamische rendering en geen cache.
- Geen globale client state library tenzij een concrete, goedgekeurde noodzaak ontstaat; URL-filters en serverstate zijn leidend.

- Databasewijzigingen uitsluitend via geversioneerde Supabase-migraties; geen handmatige productieaanpassingen zonder migratie.

10.3 Routes en schermen

Route	Werkvlak	Doel
/login	Leden	E-mailadres invoeren.
/login/code	Leden	Zescijferige code verifiëren.
/mijn-tenue	Leden	Dashboard met gekoppelde ledenkaarten.
/mijn-tenue/lid-toevoegen	Leden	Ongekoppelde leden met hetzelfde e-mailadres kiezen.
/mijn-tenue/account	Leden	Koppelingen, sessies en uitloggen.
/betaling/[orderId]	Leden	Server start of hergebruikt Mollie-betalpoging.
/betaling/terug	Leden	Neutrale terugkeerpagina; webhook blijft leidend.
/backoffice	Backoffice	Dashboard.
/backoffice/leden	Backoffice	Ledenlijst, filters en detailldrawer.
/backoffice/artikelen	Backoffice	Artikelen en varianten.
/backoffice/bestellingen	Backoffice	Orders, bedrag en regels.
/backoffice/betalingen	Backoffice	Betaalregister en handmatige registratie.
/backoffice/leveringen	Backoffice	Ontvangsten, voorraad en reserveringen.
/backoffice/uitgifte	Backoffice	Uitgiftehistorie en correcties.
/backoffice/emails	Backoffice	Templates, jobs en bulkacties.
/backoffice/export	Backoffice	Exports en rapportselectie.
/backoffice/instellingen	Beheerder	Club, seizoen en medewerkers.
/uitgifte	Uitgifte	Scannerstart en zoeken.
/uitgifte/lid/[lookupId]	Uitgifte	Gescand/gevonden lid en uitgifteactie.

10.4 Server- en clientgrens

Secrets blijven server-only

Mollie API key, SendGrid API key, Supabase secret/service key, OTP-pepper, cronsecret en databascredentials mogen nooit een NEXT_PUBLIC_-prefix krijgen, in browserbundels voorkomen of in logs worden geschreven. Next.js omgevingsvariabelen zijn standaard server-only; alleen de Supabase publishable key mag indien nodig publiek zijn. [R4][R7]

- Parent-, payment-, email- en QR-data wordt door server actions/route handlers opgehaald na eigen autorisatiecontrole.
- Staff-data kan via een user-scoped Supabase client met RLS worden gelezen; privileged jobs gebruiken een secret key in server-only code.
- Geen gevoelige serverdata wordt als ongefilterde props naar Client Components gestuurd.
- Alle mutations valideren input opnieuw en controleren de actuele database-status om time-of-check/time-of-use fouten te voorkomen.

10.5 Achtergrondtaken

Bulk e-mail wordt niet binnen de webrequest volledig verzonden. Een email_jobs-tabel fungeert als duurzame wachtrij. Een beveiligde scheduler roept minimaal elke minuut een interne route aan die een beperkte batch claimt, verzendt en status/retry vastlegt. Dezelfde job mag nooit dubbel verzonden worden.

- Maximaal vijf pogingen met exponentiële backoff.
- Permanent falen na de laatste poging; zichtbaar in de backoffice.
- Job claiming met database-locking/skip locked zodat parallelle workers veilig zijn.
- Webhookevents worden los verwerkt en gekoppeld via provider_message_id.

11. Authenticatie, sessies en autorisatie

Medewerkers en ouders gebruiken bewust verschillende authenticatiemodellen. Medewerkers hebben expliciete, beheerde accounts met MFA. Ouders krijgen een eenvoudige tijdelijke code en een eigen server-side sessie. Beide modellen eindigen in een strikte autorisatiecontrole per request.

11.1 Medewerkers via Supabase Auth

- Account wordt uitsluitend door een beheerder aangemaakt en aan één van de drie rollen gekoppeld.
- Inloggen met e-mail en sterk wachtwoord; geen publieke registratie.
- TOTP MFA is verplicht voor alle medewerkers voordat een staff-route toegankelijk is; sessies moeten AAL2 hebben. Supabase ondersteunt het afdwingen van MFA op basis van assurance level. [R8]
- SSR-sessies worden met de officiële Supabase SSR-aanpak in cookies verwerkt; responses met gebruikerssessies worden nooit publiek gecachet. [R9]
- Geblokkeerde staff_profiles verliezen direct applicatietoegang, ook wanneer de Supabase sessie nog technisch bestaat.
- Uitloggen trekt de huidige sessie in; beheerder kan alle sessies van een medewerker beëindigen.

11.2 Ouder OTP-beveiliging

Controle	Vaste waarde/regel
Codeformaat	Zes cijfers, cryptografisch veilig gegenereerd.
Geldigheid	Exact 10 minuten.
Gebruik	Eenmalig; used_at wordt bij succes atomair gezet.
Opslag	Alleen HMAC/hash met server-pepper; plaintext code nooit in database of log.
Pogingen	Maximaal 5 per code.
Opnieuw sturen	Minimaal 60 seconden tussen aanvragen.
Rate limit	Maximaal 5 codes per uur per e-mail en aanvullende limiet per IP.
Antwoord	Generiek, ongeacht bestaan van het e-mailadres.
Sessie-token	Minimaal 32 random bytes, alleen hash opgeslagen.
Cookie	HttpOnly, Secure, SameSite=Lax, Path=/, max-age 30 dagen.

Sessietokens worden geroteerd bij login en “uitloggen op alle apparaten”. De server vergelijkt tokens constant-time, houdt last_seen_at bij en accepteert geen sessie na expires_at of revoked_at. OWASP benadrukt dat sessie-ID's onvoorspelbaar moeten zijn en veilig aan autorisatie moeten worden gekoppeld. [R10]

11.3 RLS en databasegrenzen

- RLS staat aan op iedere tabel of view die via de Supabase Data API bereikbaar is. [R5][R6]
- Secret/service keys worden uitsluitend server-side gebruikt omdat zij RLS kunnen omzeilen. [R5][R7]
- Private tabellen zijn niet opgenomen in exposed schemas.
- Beheerder- en kledingcommissierechten worden gecontroleerd op basis van auth.uid() plus staff_profiles.role en active.
- Uitgiftepolities laten nooit bulkselectie van leden toe; lookups lopen via een server endpoint met expliciet beperkte velden.
- Ouderaccounts hebben geen Supabase JWT. Iedere parent query loopt via een server-only repository die parent_session en parent_member_link controleert.
- Security definer functies zijn minimaal, hebben een vaste lege search_path en zijn alleen executeerbaar door bedoelde rollen.

11.4 CSRF, XSS en requestbeveiliging

- Alle state-changing endpoints accepteren alleen POST/PATCH/DELETE, controleren Origin/Host en gebruiken CSRF-bescherming waar cookie-authenticatie wordt gebruikt.
- SameSite cookies zijn een extra laag, niet de enige CSRF-bescherming.
- E-mailtemplate-inhoud wordt gesaniteerd; shortcodes leveren uitsluitend ge-escape data of gecontroleerde HTML-fragmenten.
- Content Security Policy beperkt scripts, frames en verbindingen tot de applicatie en noodzakelijke Mollie/SendGrid-resources.
- X-Content-Type-Options, HSTS, Referrer-Policy, frame-ancestors en Permissions-Policy worden ingesteld. Next.js ondersteunt custom response headers en adviseert CSP in productie. [R11]
- Bestandsupload controleert extensie, MIME, grootte en inhoud en wordt nooit als uitvoerbare code behandeld.

12. Mollie betalingscanon

Mollie is onderdeel van de MVP, maar kan via een server-side feature flag uitgeschakeld blijven totdat live credentials en het Mollie-profiel gereed zijn. De applicatie gebruikt de Payments API en hosted checkout. De verouderde Orders API wordt niet gebruikt. [R1][R2]

12.1 Aanmaken van een betaling

- 1Ouder kiest de betaalbutton binnen één ledenkaart.
- 2Server valideert ouder-sessie en actieve parent_member_link.
- 3Server leest member_order en amount_due_cents opnieuw uit Postgres.
- 4Bij paid wordt geen nieuwe betaling aangemaakt; bij een geldige open/pending attempt wordt deze hergebruikt.
- 5Anders wordt een lokaal payment-record met unieke idempotency key aangemaakt.
- 6Server maakt via Mollie Payments API exact amount value in EUR, beschrijving, redirectUrl, webhookUrl en interne metadata aan.
- 7De ouder wordt uitsluitend doorgestuurd naar de checkout-URL uit de Mollie-response. [R1]

Mollie metadata (voorbeeld)

```
{
  "payment_id": "<interne UUID>",
  "order_id": "<interne UUID>",
  "member_id": "<interne UUID>",
  "season_id": "<interne UUID>",
  "schema_version": 1
}
```


12.2 Webhook is leidend

Redirect is nooit betaalbewijs

De terugkeerpagina na Mollie mag een bestelling niet zelf als betaald markeren. Alleen server-side verwerking van de actuele Mollie payment-status kan dit doen.

- 1 Webhookroute ontvangt het Mollie-event via HTTPS.
- 2 Event wordt op idempotency/provider-ID gecontroleerd en veilig gelogd zonder secrets.
- 3 De server haalt het payment-object opnieuw op bij Mollie via de geheime API key; Mollie documenteert statusupdates via webhooks en het ophalen van de payment. [R2][R3]
- 4 Server vergelijkt provider_id, lokale payment_id, order metadata, currency EUR en exact amount.
- 5 Alleen status paid mag de lokale payment en order definitief op betaald zetten.
- 6 De verwerking gebeurt in één database-transactie en kan zonder dubbele gevolgen herhaald worden.
- 7 Webhook retourneert 200 na succesvolle of reeds verwerkte afhandeling; tijdelijke fouten leiden tot retry.

12.3 Idempotentie en dubbele betalingen

- Payment-create gebruikt een stabiele idempotency key per lokale poging, omdat Mollie idempotentie adviseert om dubbele betalingen te voorkomen. [R3]
- Webhookevents hebben een unieke provider event/payment combinatie.
- De orderupdate gebruikt een voorwaarde “nog niet paid” en schrijft paid_at maximaal één keer.
- Als twee verschillende Mollie-betalingen onverhoopt beide paid worden, blijft de eerste de orderbetaling en wordt de tweede als duplicate_paid gemarkeerd voor handmatige afhandeling; de QR wordt niet twee keer gewijzigd.
- Een nieuwe poging mag pas worden aangemaakt wanneer de vorige attempt niet meer bruikbaar/open is of expliciet is verlopen.

12.4 Handmatige kas- en pinbetaling

- 1 Beheerder of kledingcommissie opent de bestelling.
- 2 Systeem toont het vaste bedrag; er is geen bewerkbaar bedragveld.
- 3 Medewerker kiest Kas of Pin en bevestigt in een dialog met lid, seizoen en bedrag.
- 4 Server controleert dat de order nog niet paid is en schrijft exact amount_due_cents.
- 5 Order wordt paid en QR wordt actief; de betalingsbevestiging wordt als e-mailjob klaargezet.

12.5 Terugbetalingen en correcties

Het starten van een Mollie-refund vanuit het portaal is buiten scope. Als een refund in Mollie wordt uitgevoerd, moet het portaal de status via webhook/API als refunded verwerken. De QR wordt geblokkeerd en nog niet uitgegeven regels kunnen niet worden uitgegeven. Een reeds uitgegeven tenue wordt niet automatisch teruggedraaid; dit vereist een operationele correctie buiten de betaalflow.

12.6 Mollie productie-gate

- Aparte test- en live-API keys; live key uitsluitend in productie-secretstore.
- Publiek bereikbaar HTTPS-webhookendpoint en succesvol end-to-end getest.
- Testscenario's voor paid, failed, canceled, expired, duplicate webhook, vertraagde webhook en refund.
- Dagelijks betaalreconciliatie-overzicht: lokaal paid versus Mollie paid.
- Privacyverklaring, contactinformatie en betaalomschrijving zijn door Duindorp SV gecontroleerd.
- Geen kaartgegevens, IBAN, betaalmethodegegevens of checkoutformulieren in de eigen applicatie.

13. QR-code- en uitgiftebeveiliging

De QR-code is een willekeurige bearer identifier, geen digitaal ledenpasje met persoonsgegevens. De code bevat minimaal 256 bits entropie en encodeert een versie plus random token of een HTTPS-URL met dat token. Alleen de hash wordt in de database opgeslagen.

Eigenschap	Vaste regel
Bereik	Precies één member_order in één seizoen.
Persoonsgegevens	Geen naam, e-mail, relatienummer, bedrag of artikelgegevens in QR-payload.
Activering	Token kan bestaan vóór betaling, maar uitgifte is alleen toegestaan bij paid.
Levensduur	Geldig gedurende het seizoen totdat ingetrokken of geroteerd.
Rotatie	Nieuwe token, oude onmiddellijk inactive; reden en actor gelogd.
Scanner	Alleen ingelogde medewerker kan token resoven.
Openen buiten scanner	Neutrale pagina zonder liddata; instructie dat de code bij uitgifte wordt gescand.
Logging	Scanresultaat, actor, tijd en resultaat; token zelf niet loggen.

De fulfilmenttransactie vergrendelt de geselecteerde orderregels, controleert de actuele betaalstatus en gebruikt unieke constraints. Hiermee wordt race-conditiongedrag bij twee balies voorkomen. Een fout vóór commit geeft geen gedeeltelijke uitgifte.

14. SendGrid en communicatiecanon

SendGrid wordt uitsluitend gebruikt voor transactionele clubcommunicatie binnen het tenueproces. De Mail Send API ondersteunt Dynamic Templates, maar de MVP bewaart de beheersbare templatebron in het portaal en gebruikt SendGrid als afleverprovider. SendGrid ondersteunt dynamische data en Handlebars-achtige vervanging; het portaal beperkt dit tot de vastgezette shortcodes. [R12][R13]

14.1 Afzender en deliverability

- Afzender is een geverifieerd Duindorp SV-domein met SPF/DKIM-configuratie.
- From-naam is "Duindorp SV Tenueportaal".
- Reply-To is het ingestelde contactadres van de kledingcommissie.
- API key heeft uitsluitend minimale Mail Send-rechten en staat server-only.
- Geen marketinglijsten, nieuwsbrieven of promotionele tracking in deze applicatie.

14.2 Templateveiligheid

- Template-editor ondersteunt tekst, eenvoudige opmaak, links en de allowlist van shortcodes.
- HTML wordt gesaniteerd vóór opslag en opnieuw vóór verzending.
- QR wordt als gecontroleerde inline afbeelding of beveiligde dashboardlink toegevoegd; nooit als onbetrouwbare externe HTML.
- Een preview gebruikt fictieve voorbeelddata, geen willekeurig echt lid.
- Templatewijzigingen krijgen een versienummer en actor in auditlog.

14.3 Bulk verzending

De operator kiest eerst een filter of expliciete regels, ziet het aantal unieke bestellingen en bekijkt een voorbeeld. Na bevestiging worden losse email_jobs gemaakt. De bulkactie is idempotent op template, order, trigger en batch zodat dubbel klikken geen dubbele e-mail veroorzaakt.

15. Import-, export- en auditcanon

Import en export zijn vaak de snelste route naar datalekken of administratieve fouten. Daarom gelden dezelfde server-side validatie, autorisatie en logging als voor betalingen.

15.1 Importveiligheid

- Upload alleen via beheerder/kledingcommissie; CSRF en MIME-controle verplicht.
- CSV-parser gebruikt expliciete kolomlimieten en maximale rij-/celgroottes om geheugenmisbruik te voorkomen.
- Geen spreadsheetformules, HTML of scripts worden uitgevoerd.
- Preview is read-only; commit gebruikt transactionele upsert en controleert relatienummerconflicten.
- Foutbestanden bevatten alleen noodzakelijke rijnummers/velden en worden niet permanent publiek opgeslagen.

15.2 Exportveiligheid

- Exports zijn alleen voor beheerder en kledingcommissie.
- De exportselectie wordt server-side opnieuw toegepast; de browser stuurt geen willekeurige SQL/filterexpressie.
- Tekst die begint met =, +, -, @, tab of carriage return wordt veilig gequote/geprefixed tegen formule-injectie.
- Bestandsnamen bevatten seizoen en aanmaakdatum, niet automatisch een ledenaam.
- Exportactie en gebruikte filters worden gelogd.

15.3 Auditlog

Actiecategorie	Voorbeelden
Authenticatie	Staff login/MFA, parent code request/verify, logout, sessierevocation.
Leden	Import, handmatige wijziging, actief/inactief, ouderlink.
Bestellingen	Aanmaken, bedrag wijzigen, regel/maat wijzigen, annuleren.
Betaling	Mollie create/status, kas/pin bevestiging, duplicate, refundstatus.
Voorraad	Ontvangst, reservering, release, correctie.
QR	Aanmaken, opnieuw sturen, intrekken, roteren, scanresultaat.
Uitgifte	Fulfilment, regeluitgifte, reversal/correctie.
E-mail/export	Templateversie, bulkbatch, jobstatus, exporttype en filters.
Beheer	Rolwijziging, feature flag, seizoen openen/archiveren.

Auditlogs bevatten nooit plaintext OTP's, sessietokens, QR-tokens, API keys of volledige webhookpayloads. Voor/na-data wordt geredigeerd en alleen relevante velden worden opgeslagen.

16. Security- en privacycanon

De applicatie verwerkt persoonsgegevens en echte betalingen. “Veilig genoeg” betekent een aantoonbare basis van least privilege, veilige sessies, inputvalidatie, sterke secrets, idempotente integraties, auditability, back-ups en geteste herstelprocedures. Het betekent niet dat het portaal zelf betaalkaartgegevens verwerkt.

16.1 Verplichte technische maatregelen

Domein	Maatregel
Transport	HTTPS-only, HSTS en veilige cookies; geen productie over onbeveiligd HTTP.
Secrets	Secretstore/environment, nooit git, browser, foutmelding of log. Rotatieprocedure aanwezig.
Autorisatie	Server-side RBAC plus RLS/constraints; client-side verbergen is nooit autorisatie.
Input	Zod, lengte-/formaatlimieten, allowlists en databasechecks.
Output	HTML escaping/sanitizing, CSP en geen onbetrouwbare dangerouslySetInnerHTML.
Sessies	Onvoorspelbare tokens, HttpOnly/Secure/SameSite, rotatie en revocation.
MFA	AAL2 verplicht voor alle medewerkers.
Rate limit	OTP, verificatie, Mollie create, QR lookup, zoeken en exports.
Webhooks	Authenticiteit/status server-side controleren, idempotent, geen blind payloadvertrouwen.
Database	Private schemas, RLS, least-privilege grants, constraints en transacties.
Logging	Gestructureerd, geredigeerd, correlation-id; geen secrets/tokens.
Back-up	Dagelijkse back-up en periodieke hersteltest; productie en staging gescheiden.

16.2 Privacy en bewaartermijnen

De applicatie volgt gegevensminimalisatie en bewaart persoonsgegevens niet langer dan noodzakelijk. De Autoriteit Persoonsgegevens hanteert als uitgangspunt dat gegevens moeten worden verwijderd zodra zij niet meer nodig zijn. [R15][R16]

Gegevens	Retentiecanon
OTP-codes	Na gebruik of verloop direct onbruikbaar; technisch verwijderen uiterlijk na 24 uur.
Rate-limit events	Maximaal 30 dagen, tenzij onderdeel van een beveiligingsincident.
Oudersessies	Verwijderen uiterlijk 30 dagen na expiratie/revocation.
E-mail provider-events	12 maanden voor afleverproblemen en support.
Actieve leden/orderdata	Gedurende actieve seizoenen en noodzakelijke operationele nazorg.
Uitgiftehistorie	Minimaal twee volledige seizoenen; daarna beoordelen/anonymiseren voor zover niet financieel nodig.
Financiële administratie	Zeven jaar wanneer de gegevens onderdeel zijn van de fiscale administratie; de Belastingdienst noemt voor basisadministratie een bewaartermijn van 7 jaar. [R14]
Auditlog	Minimaal 24 maanden; betaalgerelateerde audit volgt de financiële retentie.

Verwijderen van een ouderkoppeling verwijdert niet automatisch betaling of uitgiftehistorie. Bij een AVG-verzoek moet Duindorp SV bepalen welke gegevens nog wettelijk of operationeel noodzakelijk zijn en overige gegevens verwijderen of anonimiseren.

16.3 Beveiligingsincidenten

- Er is een contactpersoon en incidentprocedure voor verloren staff-account, gelekte QR, verdachte betaling en datalek.
- Beheerder kan staff-account blokkeren, ouder-sessies intrekken en QR-token roteren zonder database-ingreep.
- Alle productie-acties krijgen correlation-id zodat logs tussen Next.js, Supabase, Mollie en SendGrid te volgen zijn.
- Bij een ernstig incident wordt Mollie/SendGrid-functionaliiteit via server-side feature flag uitgeschakeld zonder de handmatige administratie te verwijderen.

17. Niet-functionele eisen

Categorie	Minimumacceptatie
Capaciteit	Minimaal 1.500 leden, 10.000 orderregels, 25 gelijktijdige staffsessies en bulkmail naar 2.000 orders.
Respons	Normale pagina-interactie < 2 seconden; QR-lookup en fulfilmentbevestiging p95 < 2 seconden bij normale verbinding.
Beschikbaarheid	Doel 99,5% tijdens seizoen; gepland onderhoud buiten aangekondigde afhaalmomenten.
Toegankelijkheid	Kernflows voldoen aan WCAG 2.2 AA: toetsenbord, focus, contrast, labels en status niet alleen op kleur.
Responsive	Ledenportaal vanaf 360 px; uitgifte optimaal vanaf 768 px; backoffice primair vanaf 1280 px.
Browsers	Actuele en vorige hoofdversie van Chrome, Edge en Safari; mobiele Safari/Chrome voor leden.
Camera	Scanner gebruikt camera waar ondersteund; zoeken blijft fallback.
Herstel	RPO maximaal 24 uur en RTO maximaal 4 uur voor database/applicatieherstel.
Observability	Foutlogs, webhookstatus, jobwachtrij, mislukte mails en betaalverschillen zichtbaar/alertbaar.
Data-integriteit	Geen dubbele order per lid/seizoen, geen dubbel uitgegeven regel en geen paid bij afwijkend bedrag.

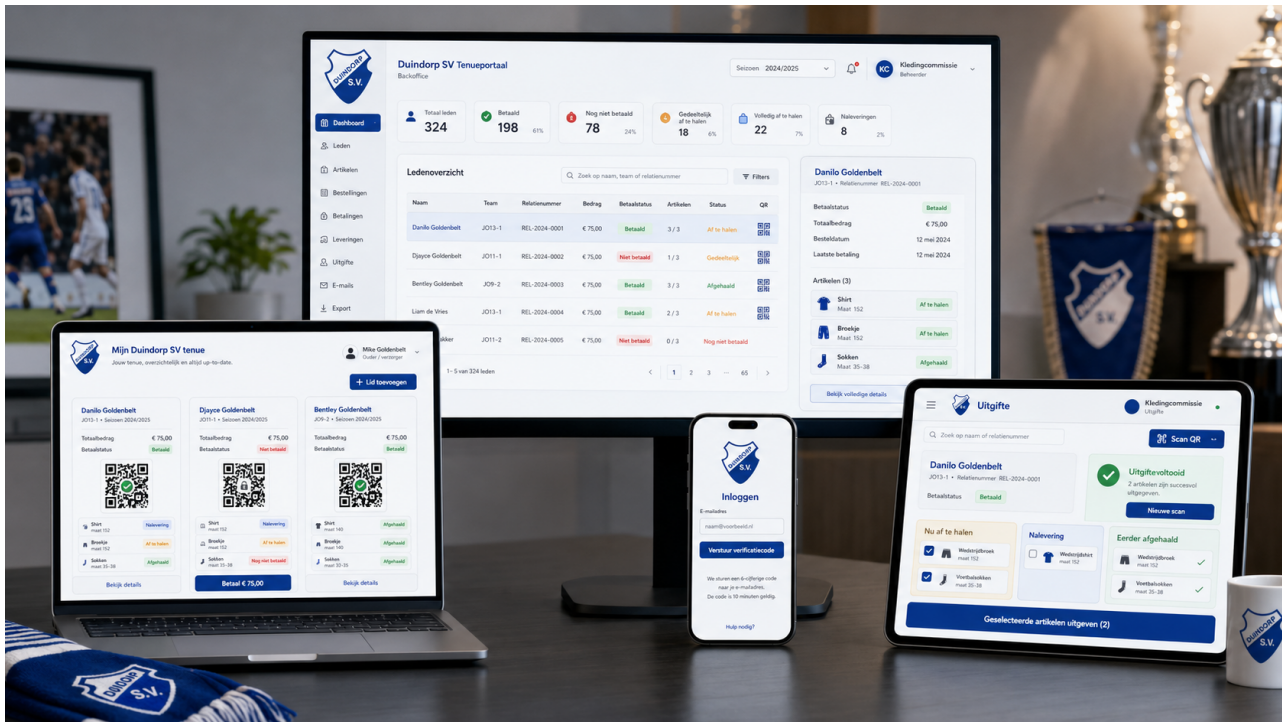
17.1 Foutafhandeling

- Gebruikers zien Nederlandse, actiegerichtte foutteksten zonder stacktraces of providerdetails.
- Retrybare fouten behouden de ingevoerde selectie en geven een duidelijke opnieuw-proberen actie.
- Een time-out bij uitgifte toont geen succes voordat de servercommit bevestigd is.
- Mollie- of SendGrid-storing degradeert gecontroleerd: administratie blijft bereikbaar, betaling/mail toont tijdelijk niet beschikbaar.
- Lege staten leggen de volgende actie uit; geen kale lege tabellen.

18. Designcanon

Visuele bron van waarheid

De hieronder opgenomen gecombineerde showcase is de bindende visuele richting. De voorbeelddata en jaartallen in de afbeelding zijn illustratief; de componentstijl, ruimtelijkheid, hiërarchie, kleurverdeling en samenhang tussen de drie werkvlakken zijn canoniek.



Canonieke Enterprise SaaS showcase: Backoffice op desktop, ledenportaal op laptop, e-mailcode login op mobiel en Uitgifte op tablet - één consistent Duindorp SV design system.

18.1 Merkidentieit

 Brand 900 #0B2E63	 Brand 700 #17418B	 Brand 500 #2E69CC
 Achtergrond #F6F8FB	 Tekst #172033	 Rand #DDE3EC
 Succes #17804A	 Waarschuwing #A85C05	 Fout #B42318

- Het officiële Duindorp SV-schild wordt ongewijzigd gebruikt. Geen nieuwe letters, schaduwen, contouren of alternatieve clubkleuren.
- Brand 700 (#17418B) is de primaire kleur voor navigatie, actieve states en hoofdknoppen.
- Brand 900 is voor titels en diep contrast; Brand 50/100 voor geselecteerde rijen en zachte panelen.
- Wit is de dominante oppervlaktekleur; de algemene achtergrond is lichtgrijs, nooit druk of decoratief.
- Succes, waarschuwing en fout hebben vaste semantische kleuren en mogen niet als decoratie worden ingezet.

18.2 Typografie

Rol	Specificatie
Lettertype	Inter voor alle UI- en documentteksten; monospace alleen voor technische IDs/shortcodes.
Pagina H1	32/40 px desktop, 28/36 px mobiel, semibold/bold.
Sectiekop	20/28 px.
Kaarttitel	16/24 px semibold.
Body/UI	14/22 px standaard.
Small/meta	12/18 px, uitsluitend secundaire informatie.
Getallen/KPI	Tabular numerals waar beschikbaar; bedrag altijd nl-NL valutaformat.

18.3 Layout en surfaces

- Backoffice: vaste linkerzijbalk circa 232-248 px, compacte topbar en content op een 12-koloms grid.
- Ledenportaal: maximale contentbreedte circa 1200 px; kaarten per lid met duidelijke verticale secties.
- Uitgifte: tablet-grid met scan/ledeninformatie links en succes/actie rechts; op smaller scherm één kolom.
- Standaard card radius 12 px, border 1 px #DDE3EC en zeer subtiele schaduw; geen zware glas- of neon-effecten.
- Binnenruimte volgt 4/8 px raster: 8, 12, 16, 24, 32 en 40 px.
- Primaire knoppen zijn koningsblauw met wit; secundair wit met blauwe/donkere rand; destructief rood uitsluitend bij echte destructie.
- Tabellen hebben een lichte header, rustige scheidslijnen, sticky header waar nodig en geselecteerde rij in Brand 50.

18.4 Componentcanon

Component	Bindend gedrag
AppShell	Zelfde logo, kleur, typografie en spacing in alle werkvlakken.
SideBarNav	Icon + label, actieve blauwe pill/achtergrond, geen submenu's in MVP.
Topbar	Seizoen/rol/account; maximaal één primaire actie.
MetricCard	Label, groot getal, optioneel percentage; klikbaar indien filterdoel bestaat.
DataTable	Zoeken, filters, paginering, selectie en detaildrawer; geen horizontale chaos.
StatusBadge	Vaste tekst, kleur en icon optioneel; betekenis ook in tekst.
MemberKitCard	Naam/team, bedrag/betaling, QR en artikelregels in één card.
QRPanel	Voldoende witruimte/contrast; locked state toont slot en reden.
ArticleRow	Artikelicoon, naam, maat en statusbadge; dezelfde vorm in alle drie werkvlakken.
ScannerPanel	Grote scanactie, duidelijke camera-state en fallback zoeken.
FulfilmentChecklist	Tapdoel minimaal 48 px; alleen gereedstaande regels selecteerbaar.
SuccessPanel	Groene check, resultaat, tijdstip, aantal en duidelijke volgende actie.
Dialog	Titel, context, één primaire en één secundaire actie; gevaarlijke acties vragen reden.
Toast	Korte niet-blokkerende feedback; geen essentiële informatie uitsluitend in toast.

18.5 Statuslabels en taal

Concept	Exact label
Product	Duindorp SV Tenueportaal
Ledenomgeving	Mijn Duindorp SV tenue
Staffomgeving	Backoffice
Scanneromgeving	Uitgifte
Payment open	Nog te betalen
Payment pending	Betaling wordt verwerkt
Payment paid	Betaald
Line backorder	Nalevering
Line ready	Af te halen
Line fulfilled	Afgehaald
Primary issue CTA	Geselecteerde artikelen uitgeven
Parent add action	Lid toevoegen
OTP CTA	Verstuur verificatiecode

Gebruik korte, concrete Nederlandse teksten. Vermijd jargon als fulfilment, allocation of reconciliation in de UI; die termen mogen alleen intern in code en technische documentatie voorkomen.

18.6 Motion en interactie

- Motion ondersteunt begrip: drawer 180-220 ms, statuswissel 140-180 ms, skeleton/fade zonder decoratieve bounce.
- Respecteer prefers-reduced-motion; alle functies blijven volledig bruikbaar zonder animatie.
- Buttons tonen loading state en worden tijdens submit geblokkeerd om dubbele acties te voorkomen.
- Scanner geeft zichtbare feedback en waar ondersteund een korte trilling, maar geen geluid als enige bevestiging.
- Focusering is duidelijk blauw en nooit verwijderd zonder toegankelijk alternatief.

18.7 Responsiveness

Werkvlak	Desktop	Tablet	Mobiel
Backoffice	Volledige sidebar, table + detaildrawer.	Inklapbare sidebar; tabellen horizontaal beheerst.	Alleen functioneel voor noodbeheer; geen primaire target.
Ledenportaal	2-3 ledenkaarten per rij afhankelijk van breedte.	1-2 kaarten.	Eén kaart per rij; QR groot, CTA full width.
Uitgifte	Werkt, maar niet primair.	Primaire target: twee kolommen en grote tapdoelen.	Eén kolom; camera en actie full screen.

18.8 Wat uit de showcase niet als functie geldt

Eventuele illustratieve menu-items, jaartallen, aantallen, namen, shirtsnummers en decoratieve kantoorobjecten in de mock-up zijn geen functionele requirements. De actuele canonieke routes, teksten en functies uit dit document hebben voorrang. Het ontwerp mag echter niet afwijken naar een andere visuele stijl, donkere modus, kleurrijke consumentenwebshop of drie los ogende applicaties.

19. Test- en acceptatiecanon

De MVP is pas gereed wanneer de hieronder beschreven scenario's geautomatiseerd of aantoonbaar handmatig zijn getest in staging en de productie-gate is doorlopen. "Werkt op mijn machine" is geen acceptatie.

19.1 Verplichte end-to-end scenario's

ID	Scenario	Verwacht resultaat
E2E-01	Import met nieuw, bestaand, dubbel e-mail en ongeldige rij.	Correcte preview; commit alleen geldige rijen volgens canon; batch gelogd.
E2E-02	Eén e-mail, één lid.	Code 10 min; lid direct gekoppeld; dashboard zichtbaar.
E2E-03	Eén e-mail, drie leden.	Selectiescherm; één of meer kiezen; overige later via Lid toevoegen.
E2E-04	Vijf foutieve OTP-pogingen.	Code ongeldig; nieuwe code vereist; geen accountinformatie gelekt.
E2E-05	Mollie paid exact bedrag.	Payment paid, QR actief, mailjob aangemaakt.
E2E-06	Mollie paid met afwijkende metadata/bedrag.	Order niet paid; security/error event; handmatige review.
E2E-07	Dezelfde webhook drie keer.	Eén lokale statuswijziging, geen dubbele mail/QR-actie.
E2E-08	Kasbetaling exact bedrag.	Paid, immutable payment-record, actor gelogd.
E2E-09	Broek/sokken ontvangen, shirt niet.	Twee regels Af te halen, shirt Nalevering; bulkmail per lid.
E2E-10	QR scan onbetaald.	Geen uitgifte mogelijk.
E2E-11	QR scan betaald met twee regels gereed.	Selectie en atomaire uitgifte; regels Afgehaald.
E2E-12	Twee apparaten geven dezelfde regel tegelijk uit.	Slechts één commit; tweede krijgt actuele conflictmelding.
E2E-13	Nalevering later binnen.	Zelfde QR; alleen shirt wordt uitgegeven.
E2E-14	QR roteren.	Oude code ongeldig; nieuwe actief; mail kan opnieuw worden gestuurd.
E2E-15	Export met naam beginnend met =.	Bestand opent zonder formule-uitvoering.
E2E-16	Uitgifterol probeert backoffice/API.	403/redirect; geen dataresponse.
E2E-17	Parent probeert niet-gekoppeld member_id.	404/403; geen liddata.
E2E-18	SendGrid tijdelijk onbeschikbaar.	Job retry; UI toont status; geen dubbele verzending.

19.2 Testlagen

- Unit: statusafleiding, bedragformatter, shortcode-rendering, token hashing en validaties.
- Database: constraints, RLS, rolepolities, transities, voorraadberekening en concurrency.
- Integratie: Mollie testmode, SendGrid sandbox/test, webhook idempotentie en job queue.
- E2E: alle primaire flows in echte browser met desktop, tablet en mobiel viewports.
- Security: autorisatie-matrix, CSRF, rate limiting, e-mailenumeratie, secret scan, dependency audit en headercontrole.
- Toegankelijkheid: toetsenbordflow, screenreaderlabels, contrast, focus, foutmeldingen en reduced motion.

19.3 Definition of Done per feature

- Functionele acceptatiecriteria uit dit canon zijn voldaan.
- Types, lint, unit/integratie en relevante Playwright-tests slagen.
- RLS/autoriteitstest toont geen toegang buiten rol of ouderkoppeling.

- Auditlog is aanwezig voor de actie.
- Fout- en lege staten zijn ontworpen en geïmplementeerd.
- Responsive en toegankelijkheidscontrole is uitgevoerd.
- Geen TODO, hardcoded voorbeelddata, testkey of verborgen niet-MVP functionaliteit in productie.
- Technische documentatie en migratie zijn bijgewerkt.

20. Omgevingen, deployment en beheer

Er zijn minimaal local, staging en production omgevingen. Staging en production hebben afzonderlijke Supabase-projecten, secrets en Mollie/SendGrid-configuraties. Productiedata wordt niet naar staging gekopieerd zonder anonimisering.

Onderwerp	Canon
Hosting	Next.js Node-runtime in een EU-regio of gelijkwaardige privacygeschikte regio, achter HTTPS. Provider is implementatiekeuze zolang eisen worden gehaald.
Database	Supabase-project in EU-regio; dagelijkse back-up en herstelprocedure.
CI	Pull request checks: typecheck, lint, tests, build, migration lint en secret scan.
CD	Staging automatisch na merge; productie via expliciete goedkeuring en release-tag.
Migraties	Voor appdeploy toegepast met rollback/forward-fix plan; geen destructieve wijziging zonder back-up.
Secrets	Per omgeving gescheiden; rotatie gedocumenteerd.
Feature flags	Alleen mollie_enabled en email_enabled als operationele safety switches; geen scopeflags.
Monitoring	Health endpoint, jobqueue, webhookfouten, betaalverschillen en databasefouten.
Onderhoud	Dependencypatches periodiek; major upgrades uitsluitend via geteste change.

20.1 Releaseprocedure

- 1Staging database migreren en seed met fictieve Duindorp SV testleden.
- 2Volledige E2E- en securityacceptatie uitvoeren.
- 3Mollie testmode en SendGrid test-/sandboxscenario's afronden.
- 4Productieback-up en rollback/forward-fix plan bevestigen.
- 5Migraties uitvoeren en applicatie deployen.
- 6Smoke test: staff login/MFA, ouder OTP, orderdashboard, manual payment testdata, QR lookup en mailjob.
- 7Mollie live pas activeren na live webhooktest en reconciliatiecontrole.
- 8Releaseversie en canonversie in backoffice footer vastleggen.

21. Verplichte bouwvolgorde

De bouwvolgorde volgt de afhankelijkheden. Het project wordt niet opgesplitst in losstaande prototypes die later moeten worden samengevoegd. Iedere stap levert een werkende verticale doorsnede op dezelfde architectuur en hetzelfde design system.

Stap	Oplevering	Acceptatiepunt
1. Fundament	Next.js, Supabase migrations, staff Auth/MFA, rollen, app shell, design tokens, auditbasis.	Drie routegroepen afgeschermd en visueel consistent.
2. Leden en catalogus	Seizoenen, Sportlink import, leden, artikelen, varianten.	Importpreview/commit en dataconstraints werken.

Stap	Oplevering	Acceptatiepunt
3. Orders en handmatig betalen	Order per lid, regels/maten, exact bedrag, kas/pin register.	Geen deel/gezinsbetaling mogelijk.
4. Ouderportaal	OTP/sessies, kandidaten koppelen, member cards, locked QR.	Meerdere kinderen optioneel en veilig.
5. Levering en uitgifte	Voorraadontvangst, reservering, QR-token, scanner, atomaire fulfilment.	Complete deel-leveringsflow werkt.
6. Mollie en e-mail	Payments API/webhook, SendGrid templates/jobs/events, bulkmail.	Idempotentie en exacte bedragen getest.
7. Export en hardening	Exports, retention jobs, monitoring, headers, rate limits, accessibility.	Productie-gate en alle E2E-scenario's groen.

Eerste werkende keten

De eerste end-to-end mijlpaal is: importeren -> order maken -> kas/pin exact betalen -> broek/sokken ontvangen -> gereedmail -> QR scannen -> gedeeltelijk uitgeven -> shirt naleveren -> zelfde QR -> afronden.

22. Definitieve MVP-acceptatie

De MVP wordt pas als vastgezet en inzetbaar beschouwd wanneer de onderstaande go-live criteria gezamenlijk zijn afgevinkt door Duindorp SV en de uitvoerende ontwikkelaar.

Gate	Vereiste
Scope	Alle in-scope functies werken; alle out-of-scope functies ontbreken.
Design	Alle drie werkvlakken volgen dezelfde componenten, tokens en showcase-richting.
Rollen	Exact drie medewerkersrollen; negatieve autorisatietests slagen.
Ouderlogin	E-mailcode 10 minuten; geen wachtwoord/magic link; veilige sessie.
Gezin	Kandidaten met hetzelfde e-mailadres optioneel koppelbaar; niet automatisch allemaal.
Betaling	Exact per lid; kas, pin en Mollie; geen deel- of combibetaling.
Levering	Deel- en nalevering per regel met voorraadreservering.
QR/uitgifte	Eén QR per lid/seizoen, live status, atomaire uitgifte en audit.
E-mail	SendGrid templates/shortcodes, bulkjobs, bounce/failure inzicht.
Export	Vastgezette exports, juiste filters en formule-injectiebescherming.
Security	MFA, RLS, rate limits, headers, secret scan, webhook/idempotentietests.
Operations	Back-up/herstel, monitoring, incidentacties en releaseprocedure getest.
Documentatie	README, environment matrix, migraties en dit canon corresponderen met productie.

23. Wijzigingsbeheer na akkoord

Na akkoord op deze canon is scope creep niet toegestaan. Een wijziging begint met een korte change request en wordt pas gebouwd nadat product-, data-, security-, design- en testimpact zijn beschreven en goedgekeurd.

Stap	Vereist resultaat
1. Aanvraag	Probleem, gewenste uitkomst en reden; geen technische oplossing als uitgangspunt.
2. Classificatie	Bug tegen canon, verduidelijking zonder scope, of nieuwe functionaliteit.

Stap	Vereist resultaat
3. Impact	Schermen, rollen, data, migratie, betaling, privacy, e-mail, tests en beheer.
4. Besluit	Goedgekeurd, afgewezen of naar toekomstige backlog.
5. Canonupdate	Versienummer en gewijzigde paragrafen vóór implementatie.
6. Bouw en acceptatie	Zelfde kwaliteitspoorten als de MVP.

Bug versus wijziging

Afwijking van dit document is een bug. Nieuwe wens die niet in dit document staat is een scopewijziging, ook wanneer de codewijziging technisch klein lijkt.

Bijlage A. 25 toekomstige ideeën - expliciet geen MVP

Deze ideeën zijn uitsluitend een gecontroleerde toekomstlijst. Zij mogen niet als verborgen voorbereiding, extra menu-item of onafgemaakte tabel in de MVP verschijnen, tenzij een latere canonversie ze formeel toevoegt.

Nr.	Idee	Korte omschrijving
1	Automatische Sportlink synchronisatie	Geplande API-import met delta's en conflictbeheer.
2	Maatbevestiging door ouder	Ouder bevestigt of wijzigt voorgestelde maat vóór een deadline.
3	Ruil- en retourworkflow	Terugontvangst, nieuwe maat, voorraadmutatie en audit.
4	Gezamenlijke gezinscheckout	Meerdere afzonderlijke orders in één betaling met correcte allocatie.
5	Deelbetalingen of termijnen	Alleen met nieuwe betaal- en uitgifteregels.
6	Sponsor- en kortingsregelingen	Vouchers, vrijstellingen en verantwoordingsrapportage.
7	Afhaaltijdsloten	Capaciteit per tijdvak en afspraakbevestiging.
8	Offline uitgiftemodus	Versleutelde lokale queue en gecontroleerde synchronisatie.
9	Leveranciersportaal	Free-Kick kan leveringen en verwachte data zelf invoeren.
10	Barcode-inname	Pakbon/maat scannen bij binnenkomst van voorraad.
11	Voorraadprognose	Vraag per maat, tekorten en verwachte naleveringen.
12	Boekhoudkoppeling	Export/API naar financieel pakket en grootboekcodes.
13	Facturen of kwitanties	Genummerde documenten en fiscale configuratie.
14	SMS of WhatsApp notificaties	Alleen na privacy-, consent- en providerkeuze.
15	Pushnotificaties	Web Push voor gereedmelding en herinneringen.
16	Apple/Google Wallet-pas	QR-code als digitale walletkaart per lid.
17	Automatische herinneringsregels	Geplande betaal- en afhaalherinneringen met limieten.
18	Seizoenskopie	Artikelen en voorgestelde maten uit vorig seizoen overnemen.
19	Geavanceerde dashboards	Trends, teams, doorlooptijd en voorraadprestatie.
20	Multi-club SaaS	Tenantisolatie, eigen branding en abonnementsbeheer.

Nr.	Idee	Korte omschrijving
21	Meertaligheid	Engels en andere talen met vertaalbeheer.
22	KNVB/SSO login	Externe identity provider in plaats van e-mailcode.
23	Native mobiele app	iOS/Android voor ouders of uitgifte.
24	Clubshop	Extra kleding, voorraad, winkelmand en verzending.
25	Vrijwilligers- en locatieplanning	Rosters, balies, locaties en shiftverantwoordelijkheid.

Bijlage B. Serverendpoint-canon

Dit overzicht beschrijft de noodzakelijke externe en interne servergrenzen. Waar Next.js Server Actions worden gebruikt, blijven dezelfde validatie- en autorisatieregels gelden.

Methode / route	Toegang	Doel en kerncontrole
POST /api/parent-auth/request-code	Publiek	Generieke response, rate limit, code 10 min, SendGrid job.
POST /api/parent-auth/verify-code	Publiek	Hash/expiry/attempts, single-use, parent session cookie.
POST /api/parent-auth/logout	Ouder	Huidige sessie revoken en cookie verwijderen.
POST /api/parent-auth/logout-all	Ouder	Alle sessies van parent_account revoken.
GET /api/parent/members	Ouder	Alleen actief gekoppelde leden en minimale dashboardview.
GET /api/parent/candidates	Ouder	Alleen ongekoppelde actieve leden met hetzelfde e-mailadres.
POST /api/parent/member-links	Ouder	Candidate opnieuw controleren en link aanmaken.
DELETE /api/parent/member-links/[id]	Ouder	Alleen eigen link soft-unlinken.
POST /api/payments/mollie/create	Ouder	Exact orderbedrag, idempotente attempt, checkout URL.
POST /api/webhooks/mollie	Mollie	Providerstatus ophalen, exact valideren, idempotent verwerken.
POST /api/webhooks/sendgrid	SendGrid	Event authenticiteit/ID, delivery/bounce status.
POST /api/internal/jobs/email	Cronsecret	Jobs claimen, verzenden, retry/status.
POST /api/imports/preview	Beheerder/Kledingcommissie	CSV parsen, mapping en foutpreview.
POST /api/imports/commit	Beheerder/Kledingcommissie	Checksum/mapping hercontroleren, transactionele upsert.
POST /api/payments/manual	Beheerder/Kledingcommissie	Kas/pin, locked exact bedrag, paid transaction.
POST /api/stock/receipts	Beheerder/Kledingcommissie	Levering en aantallen registreren.
POST /api/stock/reservations	Beheerder/Kledingcommissie	Voorraad controleren, regels ready zetten.
POST /api/email/bulk	Beheerder/Kledingcommissie	Filterselectie, previewtoken en jobs idempotent aanmaken.
POST /api/qr/rotate	Beheerder/Kledingcommissie	Reden verplicht, oude token revoken, nieuwe hash.
POST /api/fulfilment/lookup	Uitgifte+	Token/zoekterm, minimale data, rate limit en audit.
POST /api/fulfilment/commit	Uitgifte+	Paid + ready + locks; atomair fulfilment.

Methode / route	Toegang	Doel en kerncontrole
POST /api/fulfilment/reverse	Beheerder/Kledingcommissie	Reden, reversal en voorraad/statuscorrectie.
GET /api/exports/[type]	Beheerder/Kledingcommissie	Serverfilter, audit, CSV/XLSX stream.

Bijlage C. Configuratie- en secretmatrix

Variabele/categorie	Publiek?	Doel
NEXT_PUBLIC_SUPABASE_URL	Ja	Supabase project URL.
NEXT_PUBLIC_SUPABASE_PUBLISHABLE_KEY	Ja, met RLS	Publishable key voor staff Auth/client waar nodig.
SUPABASE_SECRET_KEY	Nee	Privileged serverjobs/parent repositories; nooit browser.
MOLLIE_API_KEY	Nee	Test of live Payments API key per omgeving.
SENDGRID_API_KEY	Nee	Minimale Mail Send API key.
PARENT_TOKEN_PEPPER	Nee	HMAC/hash voor OTP/session/QR tokens; apart per omgeving.
CRON_SECRET	Nee	Beschermt interne jobendpoint.
APP_BASE_URL	Nee/publiek configuratie	Canonical HTTPS domein voor redirects en QR.
MOLLIE_ENABLED	Nee	Operationele feature flag.
EMAIL_ENABLED	Nee	Operationele feature flag.
SENTRY/OTEL configuratie	Deels	Vendor-neutrale monitoring indien gekozen; geen PII in traces.

Bijlage D. Technische en juridische bronverwijzingen

- [R1] Mollie - Create payment, Payments API en checkout-URL.
<https://docs.mollie.com/reference/create-payment>
- [R2] Mollie - Get payment en statusupdates via webhooks.
<https://docs.mollie.com/reference/get-payment>
- [R3] Mollie - Webhooks / best practices en idempotente verwerking.
<https://docs.mollie.com/reference/webhooks-best-practices>
- [R4] Next.js - Environment variables; server-only tenzij NEXT_PUBLIC_.
<https://nextjs.org/docs/app/guides/environment-variables>
- [R5] Supabase - Securing your data; RLS en secret/service keys nooit frontend.
<https://supabase.com/docs/guides/database/secure-data>
- [R6] Supabase - Securing your API; exposed/private schema en RLS.
<https://supabase.com/docs/guides/api/securing-your-api>
- [R7] Supabase - API keys; secret key bypasses RLS en blijft server-side.
<https://supabase.com/docs/guides/getting-started/api-keys>
- [R8] Supabase - Multi-Factor Authentication en AAL2.
<https://supabase.com/docs/guides/auth/auth-mfa>
- [R9] Supabase - Server-side Auth/SSR en veilige cookie-sessies.
<https://supabase.com/docs/guides/auth/server-side>
- [R10] OWASP - Session Management Cheat Sheet.
https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html

[R11] Next.js - Production security en Content Security Policy/headers.

<https://nextjs.org/docs/pages/guides/production-checklist>

[R12] Twilio SendGrid - Mail Send API en Dynamic Templates.

<https://www.twilio.com/docs/sendgrid/api-reference/mail-send>

[R13] Twilio SendGrid - Dynamic templates en Handlebars-data.

<https://www.twilio.com/docs/sendgrid/for-developers/sending-email/using-handlebars>

[R14] Belastingdienst - Administratie in beginsel 7 jaar bewaren.

https://www.belastingdienst.nl/wps/wcm/connect/bldcontentnl/belastingdienst/zakelijk/btw/administratie_bijhouden/administratie_bewaren/administratie_bewaren

[R15] Autoriteit Persoonsgegevens - Bewaren van persoonsgegevens.

<https://www.autoriteitpersoonsgegevens.nl/themas/basis-avg/privacy-en-persoonsgegevens/bewaren-van-persoonsgegevens>

[R16] Autoriteit Persoonsgegevens - AVG in het kort en verwijderen wanneer niet meer nodig.

<https://www.autoriteitpersoonsgegevens.nl/themas/basis-avg/avg-algemeen/de-avg-in-het-kort>

Bronnen zijn geraadpleegd op 17 juli 2026. Bij implementatie worden exacte SDK- en API-versies vastgezet in het lockfile en worden breaking changes uitsluitend via gecontroleerde upgrade verwerkt. Dit document is geen juridisch of fiscaal advies; Duindorp SV blijft verantwoordelijk voor eigen beleid, verwerkersafspraken en wettelijke beoordeling.



MVP SAMENGEVAT

Eén Duindorp SV platform. Drie rollen. Eén order en exact bedrag per lid. Ouderlogin met 10-minutencode. Optioneel meerdere kinderen. Eén QR per lid en seizoen. Deel-leveringen per artikelregel. Kas, pin en veilige Mollie-betaling. SendGrid communicatie. Atomaire uitgifte. Geen extra scope.

Duindorp SV Tenueportaal

MVP Canon v1.0 - 17 juli 2026